



IT-SIMPLERA INSTITUTE

Cyber Security Analyst Internship Program

WEEK 06 ASSIGNMENT

Cybersecurity Fundamentals & Security Concepts

Prepared by: Muhammad Awais

Cyber Security Intern - Red Tea

Supervisor / Mentor: Talal Rehan

Company: IT-SIMPLERA Solutions

Submission Deadline: 8 August 2026

Table of Contents

Table of Contents	2
Introduction	4
Task 1 - Enterprise Active Directory Design	5
1.1 Network Diagram.....	5
1.2 OU Structure Diagram.....	5
1.3 Authentication Flow Diagram (User -> Domain Controller -> File Server).....	7
1.4 Two-Page Explanation.....	Error! Bookmark not defined.
A. Why each OU is placed where it is	7
B. How this design improves security	7
Task 2 - Users, Groups & Permission Planning.....	9
2.1 Users (25)	9
2.2 Security Groups (10)	10
2.3 Shared Folders (5) - Permission Matrix.....	10
2.4 Analysis Questions	10
Which account would attackers target first, and why?	11
Which permissions violate the Principle of Least Privilege, and how to fix them?	11
Task 3 - Group Policy & Security Configuration	12
Task 4 - Active Directory Practical (Windows Server)	13
Step 1 - Create one Organizational Unit	13
Step 2 - Create five users	13
Step 3 - Create two security groups	13
Step 4 - Join one Windows client to the domain.....	13
Step 5 - Add users to groups	13
Step 6 - Create one shared folder.....	14
Step 7 - Apply permissions.....	14
Step 8 - Reset one user's password	14
Step 9 - Disable one user account	14
Step 10 - Unlock one locked account.....	14
Task 5 - Basic Kali Linux Enumeration.....	15
Command 1	15
Command 2	15
Command 3	16
Command 4	17

Command 5	17
Command 6 and 7 - Domain-based DNS enumeration.....	18
Summary	18
Task 6 - Case Study & Troubleshooting	19
6.1 Ten Possible Causes	19
6.2 Step-by-Step Troubleshooting.....	19
6.3 AD Components to Check	20
6.4 Useful Windows Logs.....	20
6.5 Verifying DNS, Group Policy, and Kerberos.....	20
6.6 Final Incident Report.....	20
Incident Summary.....	20
Root Cause	20
Resolution	21
Preventive Recommendations	21
Challenges Faced.....	22
Conclusion.....	22
References	22

Introduction

This report documents Week 6 of the Cyber Security Analyst Internship at IT-SIMPLERA Institute. It takes on the role of a Junior System Administrator and Security Analyst for a fictional organization, TechSecure Solutions, which has 300 employees across 5 departments (HR, IT, Finance, Sales, Management) and 2 branch offices.

The report covers designing an enterprise Active Directory (AD) forest, domain, and Organizational Unit (OU) structure; planning users, security groups, and shared-folder permissions; defining Group Policy Objects (GPOs) for security hardening; a hands-on Windows Server AD lab; basic defensive enumeration of the AD lab using Kali Linux; and a troubleshooting case study with a final incident report.

Tasks 4 and 5 require hands-on execution inside a personal virtual lab (a Windows Server domain controller plus a Kali Linux VM) with a screenshot for every step, per the assignment brief. This report supplies the exact steps, commands, and explanations for each; the matching screenshots should be captured while performing the lab and dropped into the marked placeholders before final submission.

Task 1 - Enterprise Active Directory Design

TechSecure Solutions: 300 employees, 5 departments (HR, IT, Finance, Sales, Management), 2 branch offices. The design below uses 1 forest, 1 domain (techsecure.local), 2 Domain Controllers, and 8 Organizational Units.

1.1 Network Diagram

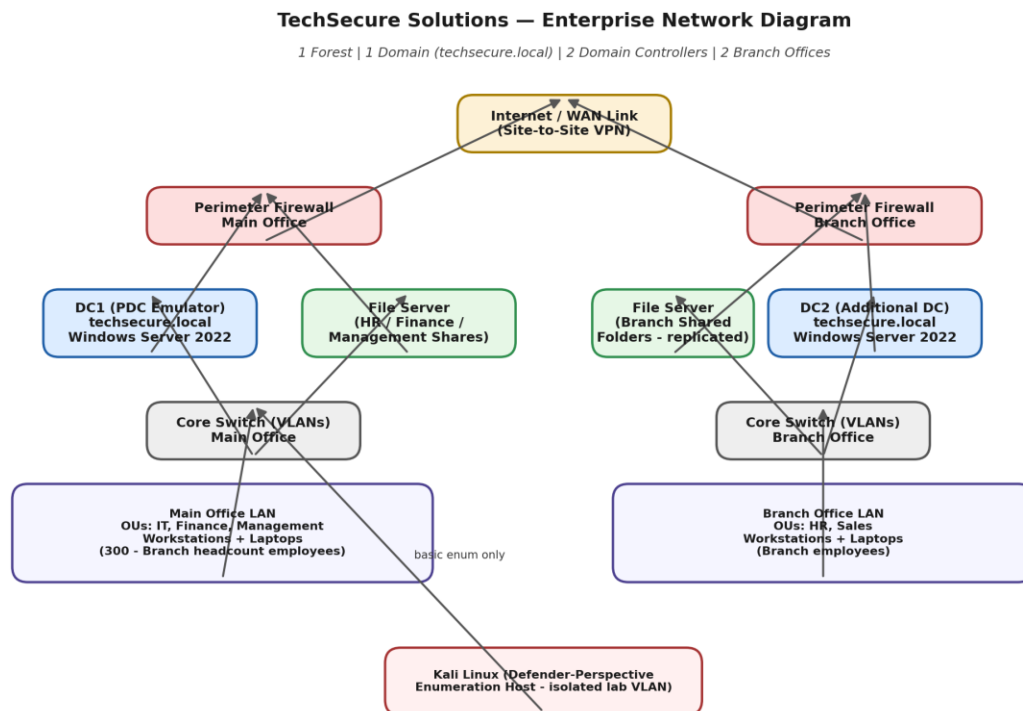


Figure 1: TechSecure Solutions enterprise network topology across the main and branch offices.

1.2 OU Structure Diagram

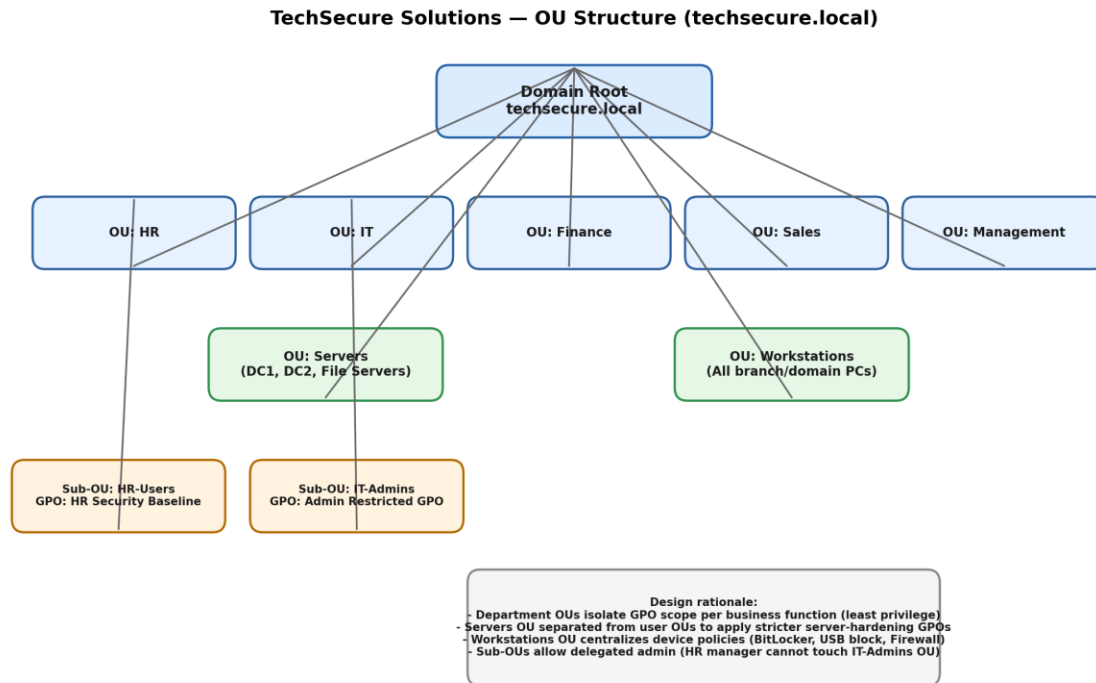


Figure 2: Organizational Unit structure under the techsecure.local domain (8 OUs: HR, IT, Finance, Sales, Management, Servers, Workstations, plus delegated sub-OUs).

1.3 Authentication Flow Diagram (User -> Domain Controller -> File Server)

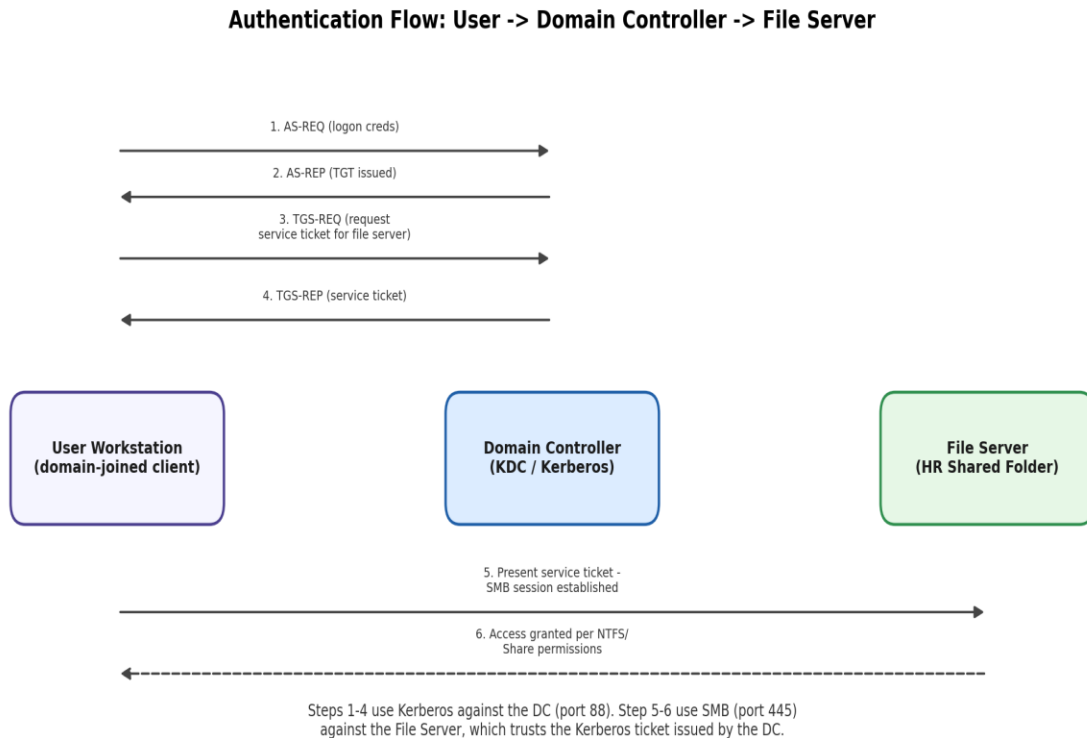


Figure 3: Kerberos-based authentication flow from a domain-joined client to the HR file server.

A. Why each OU is placed where it is

- Department OUs (HR, IT, Finance, Sales, Management) sit directly under the domain root because each department has distinct security requirements and needs its own GPOs (e.g., HR needs stricter data-handling policy, Sales needs BitLocker on laptops).
- A dedicated Servers OU holds DC1, DC2, and the file servers, separated from user/computer OUs so server-hardening GPOs (audit policy, stricter firewall rules, no USB policy) never accidentally apply to end-user machines.
- A dedicated Workstations OU centralizes device-level policies (BitLocker, Windows Update, Defender, USB restriction) that must apply uniformly to every laptop/desktop regardless of which department its user belongs to.
- Sub-OUs (e.g., IT-Admins under IT, HR-Users under HR) allow delegated administration: an HR manager can be delegated rights to reset passwords for HR-Users only, without touching the IT-Admins OU - this enforces least privilege for AD delegation itself.
- Two Domain Controllers are placed one per branch office (DC1 at the main office as PDC Emulator, DC2 at the branch as an additional DC) so each site authenticates locally and survives a WAN link outage - this also matches the 2 branch offices requirement.

B. How this design improves security

- GPO scoping by OU means a security control (e.g., Disable USB Storage) can be targeted precisely at the OUs that need it, instead of one blanket domain-wide policy that is either too loose or breaks IT's need for USB-based recovery media.
- Separating Servers from Workstations reduces the blast radius of a compromised endpoint: a phished Sales laptop is in a different OU than the Domain Controllers, so GPO-pushed lateral controls differ and admin credentials are never cached there.
- Delegated administration per OU limits how many accounts hold Domain Admin rights, directly supporting the Principle of Least Privilege and reducing the impact if a departmental admin account is compromised.
- Two Domain Controllers provide redundancy for authentication (Kerberos/LDAP) and DNS, so a single server or link failure does not lock the whole company out of the domain.
- Logical OU structure gives a clear audit trail: Group Policy audit settings applied at the Servers OU immediately show who accessed a Domain Controller or file server, aiding detection of insider threats and lateral movement.

Task 2 - Users, Groups & Permission Planning

2.1 Users (25)

Full Name	Username	Department	Job Title	Group Membership	Access Rights
Ayesha Malik	ayesha.hr1	HR	HR Manager	G-HR-Admins	Full Control - own department share
Bilal Malik	bilal.hr2	HR	HR Generalist	G-HR-Users	Read/Modify - own department share
Sara Malik	sara.hr3	HR	Recruiter	G-HR-Users	Read/Modify - own department share
Usman Malik	usman.hr4	HR	Payroll Officer	G-HR-Users	Read/Modify - own department share
Hina Malik	hina.hr5	HR	HR Assistant	G-HR-Users	Read/Modify - own department share
Ahmed Khan	ahmed.it6	IT	IT Manager	G-IT-Admins	Read/Modify - all dept shares (support role)
Zainab Khan	zainab.it7	IT	System Administrator	G-IT-Users	Read/Modify - all dept shares (support role)
Faisal Khan	faisal.it8	IT	Network Engineer	G-IT-Users	Read/Modify - all dept shares (support role)
Mahnoor Khan	mahnoor.it9	IT	Help Desk Technician	G-IT-Users	Read/Modify - all dept shares (support role)
Hassan Khan	hassan.it10	IT	Security Analyst	G-IT-Users	Read/Modify - all dept shares (support role)
Iqra Sheikh	iqra.fin11	Finance	Finance Manager	G-Finance-Admins	Full Control - own department share
Salman Sheikh	salman.fin12	Finance	Accountant	G-Finance-Users	Read/Modify - own department share
Nida Sheikh	nida.fin13	Finance	Accounts Payable Clerk	G-Finance-Users	Read/Modify - own department share
Waqas Sheikh	waqas.fin14	Finance	Accounts Receivable Clerk	G-Finance-Users	Read/Modify - own department share
Sana Sheikh	sana.fin15	Finance	Financial Analyst	G-Finance-Users	Read/Modify - own department share
Tariq Raza	tariq.sal16	Sales	Sales Manager	G-Sales-Admins	Full Control - own department share
Amna Raza	amna.sal17	Sales	Account Executive	G-Sales-Users	Read/Modify - own department share
Kashif Raza	kashif.sal18	Sales	Sales Representative	G-Sales-Users	Read/Modify - own department share
Rabia Raza	rabia.sal19	Sales	Sales Representative	G-Sales-Users	Read/Modify - own department share
Adeel Raza	adeel.sal20	Sales	Sales Coordinator	G-Sales-Users	Read/Modify - own department share

Full Name	Username	Department	Job Title	Group Membership	Access Rights
Sadia Qureshi	sadia.man21	Management	CEO	G-Management-Admins	Full Control - own department share
Junaid Qureshi	junaid.man22	Management	COO	G-Management-Users	Read/Modify - own department share
Farah Qureshi	farah.man23	Management	CFO	G-Management-Users	Read/Modify - own department share
Noman Qureshi	noman.man24	Management	Executive Assistant	G-Management-Users	Read/Modify - own department share
Alina Qureshi	alina.man25	Management	Operations Director	G-Management-Users	Read/Modify - own department share

2.2 Security Groups (10)

Group Name	Type/Scope	Purpose
G-HR-Users	Security - Global	Standard HR staff - Read/Modify on \\FS\HR
G-HR-Admins	Security - Global	HR lead/manager - Full Control on \\FS\HR
G-IT-Users	Security - Global	Standard IT staff - Read/Modify on \\FS\IT
G-IT-Admins	Security - Global	IT lead/manager - Full Control on \\FS\IT
G-Finance-Users	Security - Global	Standard Finance staff - Read/Modify on \\FS\Finance
G-Finance-Admins	Security - Global	Finance lead/manager - Full Control on \\FS\Finance
G-Sales-Users	Security - Global	Standard Sales staff - Read/Modify on \\FS\Sales
G-Sales-Admins	Security - Global	Sales lead/manager - Full Control on \\FS\Sales
G-Management-Users	Security - Global	Standard Management staff - Read/Modify on \\FS\Management
G-Management-Admins	Security - Global	Management lead/manager - Full Control on \\FS\Management

2.3 Shared Folders (5) - Permission Matrix

Folder	Read	Modify	Full Control	Denied Access
\\FS1\HR	G-HR-Users	G-HR-Admins	G-HR-Admins	All other dept groups
\\FS1\Finance	G-Finance-Users	G-Finance-Admins	G-Finance-Admins	G-Sales-Users, G-HR-Users
\\FS1\Sales	G-Sales-Users	G-Sales-Admins	G-Sales-Admins	G-Finance-Users, G-HR-Users
\\FS2\Management	G-Management-Admins	G-Management-Admins	G-Management-Admins	All staff groups except Management
\\FS1\IT-Shared	G-IT-Users	G-IT-Admins	G-IT-Admins	All non-IT groups

2.4 Analysis Questions

Which account would attackers target first, and why?

The IT Manager account (and any G-IT-Admins member) would be the first target. IT admin accounts typically hold elevated rights across multiple shares and often have local admin rights on workstations and servers, so compromising one account yields the broadest lateral-movement and privilege-escalation potential - classic path to Domain Admin. Executive Assistant/CEO accounts are a close second because of business email compromise value, but technically the IT admin account gives an attacker more direct infrastructure control.

Which permissions violate the Principle of Least Privilege, and how to fix them?

- G-IT-Users being granted Read/Modify on every department's share (support role) is broader than needed day-to-day - fix: grant IT standing Read-only access, and use a time-boxed / just-in-time elevation (e.g., temporary group membership or PAM tool) for Modify access only when a support ticket requires it.
- Domain Users having any default access to \\FS1\Finance is too broad - fix: explicitly remove Domain Users from the ACL and grant access only via G-Finance-Users/Admins.
- Department Admins (e.g., G-HR-Admins) having Full Control (not just Modify) on their own share grants unnecessary rights to change permissions/ownership - fix: split Full Control into Modify for daily work and reserve true Full Control (permission changes) for a small delegated IT/data-owner group.

Task 3 - Group Policy & Security Configuration

As IT Administrator for TechSecure Solutions, the following 10 Group Policy Objects (GPOs) are defined and linked at the appropriate OUs.

GPO	Why It Is Required	Users/OUs Affected	Attack It Helps Prevent
1. Password Complexity Policy	Enforce min 12 characters, upper/lower/number/symbol, no reuse of last 10 passwords.	All domain users	Brute-force and credential-stuffing attacks
2. Account Lockout Policy	Lock account for 15 minutes after 5 failed logon attempts within a 15-minute window.	All domain users	Password spraying and brute-force attacks
3. Disable USB Storage	Block removable-storage device class via Device Installation Restrictions GPO.	All Workstations OU (excludes IT-Admins)	Data exfiltration and USB-borne malware (e.g., BadUSB)
4. Disable CMD/PowerShell for Standard Users	Restrict cmd.exe and script execution for non-admin users via AppLocker.	All users except IT-Admins sub-OU	Living-off-the-land attacks and malicious script execution
5. Enable Windows Firewall (Domain Profile)	Force Windows Defender Firewall on, default-deny inbound, for all network profiles.	All Workstations and Servers OUs	Worm propagation and unauthorized inbound connections
6. Automatic Updates	Configure Windows Update for Business/WSUS to auto-install critical and security patches.	All Workstations and Servers OUs	Exploitation of known, unpatched vulnerabilities
7. Screen Lock / Inactivity Timeout	Force screen lock after 5 minutes idle; password required to unlock.	All domain users	Unauthorized physical access and session hijacking
8. BitLocker Drive Encryption	Mandate BitLocker with TPM protector on all laptops and removable drives.	Workstations OU, especially Sales and Management laptops	Data theft from lost or stolen devices
9. Windows Defender / Antivirus Enforcement	Force real-time protection and cloud-delivered protection on, block user from disabling.	All Workstations and Servers OUs	Malware, ransomware, and trojan infections
10. Audit Policy (Logon & Object Access)	Enable auditing of logon/logoff, account management, and file-share access; forward logs to a central collector.	Servers OU (Domain Controllers, File Servers)	Insider threats and undetected lateral movement; supports incident response

Task 4 - Active Directory Practical (Windows Server)

Performed in a personal Windows Server AD lab (Windows Server as Domain Controller + a Windows client VM). Steps below in order, with the PowerShell equivalent of each ADUC action.

Step 1 - Create one Organizational Unit

In ADUC, right-click the domain > New > Organizational Unit (e.g., "IT"). PowerShell:

```
New-ADOrganizationalUnit -Name "IT" -Path "DC=techsecure,DC=local"
```

Step 2 - Create five users

ADUC > right-click OU > New > User (repeat 5x), or PowerShell:

```
New-ADUser -Name "Ayesha Malik" -SamAccountName "ayesha.hr1" -Path  
"OU=HR,DC=techsecure,DC=local" -AccountPassword (ConvertTo-SecureString  
"P@ssw0rd123!" -AsPlainText -Force) -Enabled $true
```

Step 3 - Create two security groups

PowerShell:

```
New-ADGroup -Name "G-HR-Users" -GroupScope Global -GroupCategory Security -  
Path "OU=HR,DC=techsecure,DC=local"
```

Step 4 - Join one Windows client to the domain

On the client: System Properties > Change > Domain: techsecure.local > enter domain admin credentials > restart.

Step 5 - Add users to groups

PowerShell:

```
Add-ADGroupMember -Identity "G-HR-Users" -Members "ayesha.hr1","bilal.hr2"
```

Step 6 - Create one shared folder

Create C:\Shares\HR > right-click > Properties > Sharing > Advanced Sharing > Share name: HR.

Step 7 - Apply permissions

Security tab (NTFS) + Sharing tab (share permissions): grant G-HR-Users Modify; remove the default Everyone/Authenticated Users entry.

Step 8 - Reset one user's password

ADUC > right-click user > Reset Password, or PowerShell:

```
Set-ADAccountPassword "ayesha.hr1" -Reset -NewPassword (ConvertTo-SecureString "NewP@ss2026!" -AsPlainText -Force)
```

Step 9 - Disable one user account

PowerShell (account then shows a red down-arrow icon in ADUC):

```
Disable-ADAccount -Identity "bilal.hr2"
```

Step 10 - Unlock one locked account

ADUC > Account tab > Unlock account checkbox, or PowerShell:

```
Unlock-ADAccount -Identity "ayesha.hr1"
```

Task 5 - Basic Kali Linux Enumeration

Performed only inside the personal lab network against a host on that lab's own subnet (never against public/unauthorized systems). IP addresses are redacted in the screenshots below before publishing (e.g., to LinkedIn/GitHub).

Command 1

ping -c 4 <target-IP>

```
(kali㉿kali)-[~]
$ ping -c 4
PING ( ) 56(84) bytes of data.
64 bytes from : icmp_seq=1 ttl=128 time=1.22 ms
64 bytes from : icmp_seq=2 ttl=128 time=1.09 ms
64 bytes from : icmp_seq=3 ttl=128 time=0.949 ms
64 bytes from : icmp_seq=4 ttl=128 time=1.05 ms

--- ping statistics ---
4 packets transmitted, 4 received, 0% packet loss, time 3005ms
rtt min/avg/max/mdev = 0.949/1.075/1.216/0.095 ms
```

Figure: output of "ping -c 4 <target-IP>".

What it revealed: Target host is alive and responding to ICMP - 4/4 packets received, 0% loss, sub-2ms latency (same LAN).

Why it matters to a defender: Confirms the host is live before spending time on deeper scans - the standard first step of any recon, offensive or defensive.

Command 2

nmap -sn <subnet>/24

```
(kali㉿kali)-[~]
$ nmap -sn
Starting Nmap 7.98 ( https://nmap.org ) at 2026-08-08 14:25 +0500
Nmap scan report for
Host is up (0.0062s latency).
MAC Address: 6C:14:6E:F4:5A:98 (Huawei Technologies)
Nmap scan report for
Host is up (0.037s latency).
MAC Address: 14:1F:78:5C:5D:90 (Samsung Electronics)
Nmap scan report for
Host is up (0.081s latency).
MAC Address: 80:79:5D:43:7F:35 (Infinix mobility limited)
Nmap scan report for
Host is up (0.079s latency).
MAC Address: 92:C8:A6:CE:6B:08 (Unknown)
Nmap scan report for
Host is up (0.00068s latency).
MAC Address: 40:1C:83:97:D7:04 (Intel Corporate)
Nmap scan report for
Host is up (0.080s latency).
MAC Address: 5A:62:79:09:54:88 (Unknown)
Nmap scan report for
Host is up.
Nmap done: 256 IP addresses (7 hosts up) scanned in 7.91 seconds
```

Figure: output of "nmap -sn <subnet>/24"

What it revealed: A ping sweep of the local /24 subnet - 7 live hosts found, each with its MAC address and vendor (Huawei, Samsung, Infinix, Intel, plus 2 unknown vendors).

Why it matters to a defender: Gives a full inventory of what devices are actually on the network right now. Defenders compare this against their asset list to spot rogue/unauthorized devices.

Command 3

nmap -sV <target-IP>

```
(kali@kali)-[~]
$ nmap -sV
Starting Nmap 7.98 ( https://nmap.org ) at 2026-08-08 14:30 +0500
Stats: 0:00:04 elapsed; 0 hosts completed (1 up), 1 undergoing SYN Stealth Scan
SYN Stealth Scan Timing: About 15.00% done; ETC: 14:31 (0:00:23 remaining)
Nmap scan report for
Host is up (0.00050s latency).
All 1000 scanned ports on          are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
MAC Address: 40:1C:83:97:D7:04 (Intel Corporate)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 22.14 seconds
```

Figure: output of "nmap -sV <target-IP>"

What it revealed: All 1000 scanned TCP ports came back filtered (no response) - no open AD service ports (88/389/445/etc.) were detected on this target from the network.

Why it matters to a defender: A filtered result is itself a useful defensive finding: either the host firewall is blocking probes, or this device is not actually running AD Domain Services - both are worth documenting, since an attacker seeing this would move on to another host rather than waste time here.

Command 4

```
enum4linux-ng -A <target-IP>
```

```
(kali㉿kali)-[~]
$ enum4linux-ng -A
ENUM4LINUX - next generation (v1.3.10)

=====
| Target Information |
=====
[*] Target .....
[*] Username ..... ''
[*] Random Username .. 'zffahckh'
[*] Password ..... ''
[*] Timeout ..... 10 second(s)

=====
| Listener Scan on |
=====
[*] Checking LDAP
[-] Could not connect to LDAP on 389/tcp: timed out
[*] Checking LDAPS
[-] Could not connect to LDAPS on 636/tcp: timed out
[*] Checking SMB
[-] Could not connect to SMB on 445/tcp: timed out
[*] Checking SMB over NetBIOS
[-] Could not connect to SMB over NetBIOS on 139/tcp: timed out

=====
| NetBIOS Names and Workgroup/Domain for |
=====
[-] Could not get NetBIOS names information via 'nmblookup': timed out
[!] Aborting remainder of tests since neither SMB nor LDAP are accessible
Completed after 50.07 seconds
```

Figure: output of "enum4linux-ng -A <target-IP>"

What it revealed: LDAP (389), LDAPS (636), SMB (445), and SMB-over-NetBIOS (139) all timed out - no response on any AD/SMB-related port, so enum4linux-ng aborted further enumeration.

Why it matters to a defender: Confirms from a second, AD-focused tool that this host is not exposing directory or file-sharing services. In a real hardened AD server this is the desired outcome for unauthenticated scans; here it shows the target simply is not a live Domain Controller.

Command 5

```
smbclient -L //<target-IP>/ -N
```

```
(kali㉿kali)-[~]
$ smbclient -L // -N
do_connect: Connection to failed (Error NT_STATUS_IO_TIMEOUT)
```

Figure: output of "smbclient -L //<target-IP>/ -N"

What it revealed: Anonymous SMB share listing failed - connection timed out (NT_STATUS_IO_TIMEOUT).

Why it matters to a defender: Confirms SMB null-session share enumeration is not possible against this host, consistent with the nmap and enum4linux-ng results - no anonymous share disclosure risk found here.

Command 6 and 7 - Domain-based DNS enumeration

These two commands need an actual AD domain name to query. The scans above show this lab target is not currently answering on any AD/LDAP/SMB port, so no live Domain Controller was found on this subnet to enumerate. Once a domain name is available (from an actual running DC), run:

nslookup -type=SRV _ldap._tcp.dc._msdcs.<domain>

dig SOA <domain> @<dc-IP>

Command 6 (nslookup SRV) reveals the DC's hostname via DNS; Command 7 (dig SOA) confirms the DC is authoritative for the zone and exposes DNS serial/naming info - both are standard first steps in locating a Domain Controller from DNS alone.

Summary

- Live-host and port results show the actual attack surface as seen from the network - here, the scanned target exposed no AD-related ports, which is either strong hardening or simply not a domain-joined server.
- Cross-checking with a second AD-focused tool (enum4linux-ng) after nmap gives more confidence in the finding than either tool alone.
- No anonymous SMB share or NetBIOS disclosure was possible against this target - the desired secure outcome for unauthenticated recon.

Task 6 - Case Study & Troubleshooting

Scenario: A user reports they cannot log in to the domain, their password was changed yesterday, and they also cannot access the shared HR folder.

6.1 Ten Possible Causes

1. Password change has not yet replicated to all Domain Controllers (AD replication delay)
2. Client authenticated against a DC that has not received the new password
3. Account is locked out from failed attempts made with the old cached password
4. Windows Credential Manager on the client still holds the old cached credentials
5. Time skew between client and DC exceeds 5 minutes, breaking Kerberos authentication
6. Client DNS is not resolving the correct DC SRV records for the domain
7. A Group Policy or NTFS/share ACL denies this user access to the HR folder
8. Security token was not refreshed after a recent group-membership change (needs re-login)
9. Account was accidentally disabled or moved to a restricted OU during the reset
10. WAN/VPN link to the branch office is down, so the client cannot reach any DC at all

6.2 Step-by-Step Troubleshooting

1. Confirm the exact error message on logon (wrong password vs account locked vs account disabled vs trust relationship failed) - this immediately narrows the cause.
2. Check the user's account status in ADUC: is it locked, disabled, or expired? Use `Unlock-ADAccount` / `re-enable` if needed.
3. Verify AD replication between DC1 and DC2 with `repadmin /replsummary` and `repadmin /showrepl` to rule out a replication delay for the new password.
4. Have the user log on from a different, already-domain-joined machine to isolate whether the issue is account-wide or machine-specific (cached credential problem).
5. Check Event Viewer Security log on the DC that authenticated the failed attempt for Event ID 4625 (logon failure) and note the sub-status code (e.g., `0xC000006A` = wrong password, `0xC0000234` = account locked).
6. Verify DNS on the client (`ipconfig /all`, `nslookup` for SRV records) to confirm it is pointing at an internal DNS server that can resolve the domain and locate a DC.
7. Verify Kerberos health with `klist` and check the system clock; run `w32tm /query /status` to confirm the client is within 5 minutes of the DC's time.
8. Force a Group Policy refresh (`gpupdate /force`) and run `gpresult /r` to confirm the HR share permission GPO/ACL is applied as expected and no Deny rule is present.
9. Check the NTFS and Share permissions directly on the HR folder to confirm the user's current group membership (post password-reset) actually has access; have the user log off/on to refresh their Kerberos token if group membership changed recently.
10. If everything above checks out, test raw connectivity to the DC and file server (`Test-NetConnection <DC> -Port 88` and `-Port 445`) to rule out a firewall/VPN link issue, especially if the user is at the branch office.

6.3 AD Components to Check

- Domain Controllers (DC1 and DC2) and their replication status
- DNS server records (especially SRV records for the domain and DC)
- Kerberos Key Distribution Center (KDC) service on the DC
- The user object in ADUC (status, group membership, OU location)
- Group Policy Objects linked to the user's OU (especially security/audit and folder-redirection GPOs)
- NTFS and Share permissions on the HR file server

6.4 Useful Windows Logs

- Security log on the Domain Controller - Event ID 4625 (failed logon), 4740 (account lockout), 4767 (account unlocked)
- Security log on the client - logon failure details and Kerberos errors
- DNS Server log on the DC - resolution failures
- Directory Service log on the DC - AD replication and DC health events
- File Server Security log - Object Access audit events for the HR folder (Event ID 4663 - access attempt)

6.5 Verifying DNS, Group Policy, and Kerberos

- DNS: run `nslookup <domain>` and `nslookup -type=SRV _ldap._tcp.dc._msdcs.<domain>` from the client; both should resolve to a valid internal DC IP.
- Group Policy: run `gpresult /r /scope:user` on the client to confirm the expected GPOs (including the HR share access policy) are applied with no errors, and check `gpupdate /force` completes without failures.
- Kerberos: run `klist` on the client after logon to confirm a valid TGT was issued from the correct DC; check DC Security log for successful AS-REQ/TGS-REQ events (Event ID 4768/4769) matching the user.

6.6 Final Incident Report

Incident Summary

A user was unable to authenticate to the domain and access the HR shared folder immediately following a password reset performed the previous day.

Root Cause

The most likely root cause (to be confirmed against the actual repadmin/Event Viewer evidence gathered above) is that the new password had not yet replicated from the DC that processed the reset to the DC authenticating the user's logon, combined with a stale Kerberos ticket/cached credential on the client that referenced the old password. The HR folder access failure was a secondary symptom: the user's Kerberos token had not refreshed to include their current HR group membership.

Resolution

- Forced AD replication between DC1 and DC2 (repadmin /syncall) to ensure the new password was present on both DCs.
- Had the user log off completely and log back on (or rebooted the client) to obtain a fresh Kerberos TGT with updated group membership.
- Cleared any stale cached credentials in Windows Credential Manager on the client.
- Re-verified HR folder access after the fresh logon; access was restored.

Preventive Recommendations

- Monitor AD replication health proactively (scheduled repadmin /replsummary alerts) so replication delays are caught before they affect users.
- Educate the Help Desk to advise users to fully log off/on (not just lock/unlock) after any password reset or group membership change.
- Ensure the branch office DC (DC2) has a reliable, monitored WAN/VPN link so replication and authentication are not delayed for branch users.

Challenges Faced

- Balancing the OU design so it stays simple for a 5-department company while still meeting the 8-OU requirement and supporting delegated administration.
- Designing a permission matrix that is realistic (department isolation) while avoiding overly complex nested groups for a 300-user company.
- Task 4 and Task 5 require an actual running Windows Server + Kali Linux lab, so their evidence (screenshots) depends on hands-on execution rather than desk research; this report provides the exact steps/commands to make that execution fast.

Conclusion

This assignment reinforced core Active Directory administration concepts: forest/domain/OU design, least-privilege group and permission planning, GPO-based hardening mapped to specific attack techniques, and a structured, log-driven approach to troubleshooting real authentication issues. Completing the hands-on Windows Server and Kali Linux portions will translate this design work into practical Tier-1 SOC and system administration skill, directly supporting the SOC Analyst career target.

References

- Microsoft Learn - Active Directory Domain Services Overview
- Microsoft Learn - Group Policy Objects and Security Baselines
- Microsoft Learn - Kerberos Authentication Overview
- Kali Linux Tools Documentation - nmap, enum4linux-ng, smbclient
- IT-SIMPLERA Institute - Week 06 Assignment Brief (Talal Rehan)